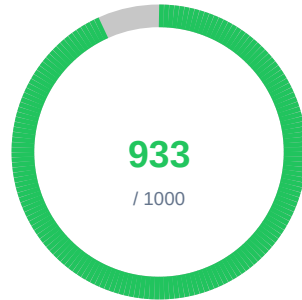


Code Hardener

ATTESTATION CERTIFICATE



bulletproof-runtime-security

Scan 749c0ae0 | Branch: main | Jul 24, 2026

Attestation ID

4ba28322-d106-43d2-9e03-...

Type

in-toto

Subject

bulletproof-runtime-security

Created

Jul 24, 2026, 4:23 PM

Subject Digest

sha256:11ac5596fa376352268018ab56af4a7f4b4fb72bf90a94663ec5ddd0...

Signature Status

CRYPTOGRAPHICALLY SIGNED

Algorithm: Ed25519 (Local Signing Key)

Signature

ye2u52YU+LOfDw+GqmIyRQT58iRSqrMV5W/g4qvGaQBewBf7VF0wVuUyYqfarUQ
9PP0K/N5c+Z+YUGoW8gKBw==

This attestation certifies the security scan was performed and results were recorded with cryptographic integrity.

Scan Report — bulletproof-runtime-security

Branch: main | Status: completed | Jul 24, 2026

933 / 1000 Score — Quality: excellent

Scan Details

Profile: standard
Duration: 17s
Started: Jul 24, 2026, 4:23 PM
Completed: Jul 24, 2026, 4:23 PM
Files Analyzed: 22
Scanners Run: 11 of 12
Open Findings: 24
Resolved / Suppressed:0
Total Detected: 24
Codebase: Python: 13 files | Markdown: 2 files | Config: 1 files | Docker: 1 files

0 Critical 0 High 8 Medium 16 Low 0 Info

Scanner Results

12 tools executed — 8 passed | 3 with open findings | 1 not applicable | 0 errors

Scanner	Category	Outcome	Findings	Duration	Files Scanned
trivy	SCA	FAIL	4	2s	4
gitleaks	Secrets	PASS	0	0s	22
opengrep	SAST	PASS	0	6s	13
checkov	IaC	PASS	0	3s	2
grype	SCA	PASS	0	3s	22
syft	SBOM	FAIL	12	1s	12
package-validator	AI Code Quality	PASS	0	0s	1

oxlint	Code Quality	N/A	0	0s	13
ruff	Code Quality	FAIL	8	0s	13
actionlint	CI/CD Security	PASS	0	0s	1
jscpd	Code Quality	PASS	0	0s	13
typos	Code Quality	PASS	0	0s	22

Scanner Evidence & Audit Trail

trivy (SCA)

FINDINGS

Scan Scope: Scanned 4 target(s): pip, dockerfile

Files Analyzed: 4

Rules Checked: 4

Checks Performed:

- Vulnerability scanning
- Misconfiguration detection
- Secret detection
- License compliance

Standards: CVE/NVD, OWASP Top 10 (A06), CIS Benchmarks, NIST SP 800-53

Methodology:

Scans filesystem for package manifests and lock files, matches installed packages against vulnerability databases (NVD, GitHub Advisory, vendor-specific). Also checks for misconfigurations and secrets using built-in rules.

Targets Analyzed:

requirements.txt, Dockerfile, requirements.txt, Loose File License(s)

gitleaks (Secrets)

PASS

Scan Scope: Working directory scanned for 150+ secret patterns with entropy analysis

Configuration: Custom gitleaks.toml

Files Analyzed: 22

Rules Checked: 150

Checks Performed:

- AWS credential detection
- API key detection
- Private key detection
- Generic secret patterns
- High-entropy string analysis
- Token detection

Standards: CWE-798, CWE-259, OWASP Top 10 (A07)

Methodology:

Regex-based pattern matching against 150+ secret patterns with entropy analysis. Scans current file contents and optionally git commit history. Applies allowlists and custom rules to reduce false positives. Secrets are redacted in output.

opengrep (SAST)

PASS

Scan Scope: Multi-language SAST with auto, security-audit, owasp-top-ten, cwe-top-25, r2c-security-audit, and secrets rulesets

Configuration: Custom semgrep-rules.yml + default rulesets

Files Analyzed: 13

Checks Performed:

- OWASP Top 10 patterns
- Security audit rules

- Secrets detection
- Injection patterns
- XSS patterns
- Insecure crypto usage

Standards: OWASP Top 10, CWE Top 25, SANS Top 25

Methodology:

Pattern-based static analysis using Semgrep rule engine with auto, security-audit, owasp-top-ten, and secrets rulesets. Matches AST patterns against known vulnerability signatures.

checkov (IaC)

PASS

Scan Scope: IaC security analysis — 0 files, 0 checks (0 passed, 0 failed), frameworks: auto-detected

Configuration: Custom .checkov.yaml

Files Analyzed: 2

Checks Performed:

- Terraform misconfigurations
- CloudFormation template issues
- Kubernetes manifest hardening
- Dockerfile best practices
- Helm chart security
- GitHub Actions security
- GitLab CI security
- Secrets in IaC files

Standards: CIS Benchmarks, NIST SP 800-53, SOC 2, PCI-DSS, HIPAA

Methodology:

Graph-based static analysis of infrastructure-as-code files. Parses IaC definitions, builds resource graphs, and checks 1000+ built-in policies covering security, networking, encryption, and compliance.

grype (SCA)

PASS

Scan Scope: SCA analysis: 0 unique CVEs across 0 vulnerable packages (filesystem)

Configuration: Grype with --by-cve deduplication and --add-cpes-if-none

Files Analyzed: 22

Checks Performed:

- CVE vulnerability matching
- Dependency version analysis
- CPE-based matching
- Advisory cross-referencing
- Fix availability detection

Standards: CVE/NVD, OWASP Top 10 (A06), GHSA

Methodology:

Generates SBOM using Syft, then matches all identified packages against vulnerability databases (NVD, GitHub Advisories, OS vendor databases). Reports CVEs with severity, fix versions, and references.

syft (SBOM)

FINDINGS

Scan Scope: SBOM of 12 packages across 1 language(s): python

Configuration: Syft with JSON + CycloneDX output for SBOM standards compliance

Files Analyzed: 12

Rules Checked: 4

Checks Performed:

- SBOM generation (Syft JSON + CycloneDX)
- License compliance analysis
- Copyleft license detection (AGPL, GPL, MPL)
- Weak copyleft classification (LGPL)
- Unknown license flagging

- Package URL (PURL) generation
- CPE generation

Standards: NTIA SBOM Minimum Elements, CycloneDX, SPDX, Executive Order 14028

Methodology:

Catalogs software packages by parsing package manifests, lock files, and installed package databases. Generates standardized SBOM in CycloneDX or SPDX format for supply chain visibility.

package-validator (AI Code Quality)

PASS

Scan Scope: Validated 10 packages across 1 dependency file(s)

Configuration: Concurrency: 10, Timeout: 5000ms per request

Files Analyzed: 1

Rules Checked: 1

Checks Performed:

- npm registry existence validation
- PyPI registry existence validation
- Go module proxy existence validation
- Slopsquatting risk detection
- Hallucinated dependency identification

Standards: CWE-829, OWASP A08:2021, SLSA Supply Chain Security

Methodology:

Parses dependency manifests and validates each package exists in its respective registry (npm, PyPI, Go proxy) via HTTP HEAD requests. Non-existent packages are flagged as hallucinated — a common AI code generation artifact that creates supply chain attack vectors.

oxlint (Code Quality)

N/A

Scan Scope: JavaScript (.js, .jsx) and TypeScript (.ts, .tsx) source files

Files Analyzed: 13

Checks Performed:

- Code correctness checks
- Suspicious code detection
- Performance anti-patterns
- Import/export validation

Standards: CWE, ESLint Core Rules

Methodology:

Rust-based linter that performs AST analysis of JS/TS files at high speed. Detects correctness issues, suspicious patterns, and performance anti-patterns.

ruff (Code Quality)

FINDINGS

Scan Scope: Python linting and security analysis via Ruff

Configuration: Default Ruff rules

Files Analyzed: 13

Checks Performed:

- Pyflakes error detection
- pycodestyle enforcement
- flake8-bandit security checks
- isort import ordering
- pep8-naming conventions
- pyupgrade modernization
- flake8-bugbear bug detection
- flake8-comprehensions optimization

Standards: PEP 8, PEP 257, CWE, OWASP Top 10

Methodology:

Rust-based Python linter implementing 800+ rules from flake8, pylint, isort, and others. 10-100x faster than traditional Python

linters.

actionlint (CI/CD Security)

PASS

Scan Scope: .github/workflows/*.yaml files

Files Analyzed: 1

Checks Performed:

- Workflow syntax validation
- Action version pinning checks
- Shell script validation
- Expression type checking
- Permissions analysis

Standards: GitHub Actions Security Best Practices, CWE-78

Methodology:

Static analysis of GitHub Actions workflow files. Validates syntax, checks for unpinned action versions, analyzes shell scripts for errors, and verifies expression types.

jscpd (Code Quality)

PASS

Scan Scope: All source files across supported languages

Files Analyzed: 13

Checks Performed:

- Cross-file duplicate detection
- Code clone identification
- Duplication percentage calculation

Standards: ISO/IEC 25010 (Maintainability)

Methodology:

Token-based analysis to detect copy-pasted code blocks across files and languages. Reports duplication percentage and identifies specific cloned regions.

typos (Code Quality)

PASS

Scan Scope: All text files in the project

Files Analyzed: 22

Checks Performed:

- Identifier spell checking
- String literal spell checking
- Comment spell checking
- Filename spell checking

Standards: ISO/IEC 25010 (Maintainability)

Methodology:

Fast, low-false-positive spell checker designed for source code. Checks identifiers, strings, and comments against a curated dictionary.

Open Findings (24)

ruff

Code Quality | 8 findings | Ultra-fast Python linter (pyflakes, pycodestyle, flake8-bandit)

Severity	Title	File	CWE / Rule
MEDIUM	Ruff F401: `fastapi.responses.PlainTextResponse` imported but unused	app/main.py:18	RUFF-F401

Fix: Auto-fix available: Remove unused import (applicability: safe)

MEDIUM Ruff F401: ``fastapi.responses.JSONResponse`` imported but unused `app/main.py:18` RUFF-F401
``fastapi.responses.JSONResponse`` imported but unused
Fix: Auto-fix available: Remove unused import (applicability: safe)

MEDIUM Ruff F401: ``datetime.timezone`` imported but unused `app/main.py:13` RUFF-F401
``datetime.timezone`` imported but unused
Fix: Auto-fix available: Remove unused import (applicability: safe)

MEDIUM Ruff F401: ``datetime.datetime`` imported but unused `app/main.py:13` RUFF-F401
``datetime.datetime`` imported but unused
Fix: Auto-fix available: Remove unused import (applicability: safe)

MEDIUM Ruff F401: ``time`` imported but unused `app/main.py:11` RUFF-F401
``time`` imported but unused
Fix: Auto-fix available: Remove unused import: ``time`` (applicability: safe)

MEDIUM Ruff F401: ``statistics`` imported but unused `...omponents/memory_integrity.py:10` RUFF-F401
``statistics`` imported but unused
Fix: Auto-fix available: Remove unused import: ``statistics`` (applicability: safe)

MEDIUM Ruff F401: ``math`` imported but unused `...omponents/memory_integrity.py:9` RUFF-F401
``math`` imported but unused
Fix: Auto-fix available: Remove unused import: ``math`` (applicability: safe)

MEDIUM Ruff F541: f-string without any placeholders `app/compliance.py:99` RUFF-F541
f-string without any placeholders
Fix: Auto-fix available: Remove extraneous ``f`` prefix (applicability: safe)

syft

SBOM | 12 findings | Software bill of materials generator for supply chain visibility

Severity	Title	File	CWE / Rule
LOW	Unknown License: uvicorn@0.34.0 Package uvicorn has no license information. This may indicate a compliance risk.	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package: uvicorn Version: 0.34.0 Type: python Fix: Verify the license for this package before using in production. OWASP: A08:2021-Software and Data Integrity Failures			
LOW	Unknown License: qdrant-client@1.12.1 Package qdrant-client has no license information. This may indicate a compliance risk.	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package: qdrant-client Version: 1.12.1 Type: python Fix: Verify the license for this package before using in production. OWASP: A08:2021-Software and Data Integrity Failures			
LOW	Unknown License: pyyaml@6.0.2	/requirements.txt	SBOM-LICENSE-UNKNOWN

Package pyyaml has no license information. This may indicate a compliance risk.

```
Package: pyyaml
Version: 6.0.2
Type: python
```

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW	Unknown License: pyjwt@2.13.0	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package pyjwt has no license information. This may indicate a compliance risk.			

```
Package: pyjwt
Version: 2.13.0
Type: python
```

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW	Unknown License: pydantic@2.10.4	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package pydantic has no license information. This may indicate a compliance risk.			

```
Package: pydantic
Version: 2.10.4
Type: python
```

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW	Unknown License: numpy@2.2.1	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package numpy has no license information. This may indicate a compliance risk.			

```
Package: numpy
Version: 2.2.1
Type: python
```

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW	Unknown License: jinja2@3.1.6	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package jinja2 has no license information. This may indicate a compliance risk.			

```
Package: jinja2
Version: 3.1.6
Type: python
```

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW	Unknown License: httpx@0.28.1	/requirements.txt	SBOM-LICENSE-UNKNOWN
Package httpx has no license information. This may indicate a compliance risk.			

```
Package: httpx
Version: 0.28.1
Type: python
```

Fix: Verify the license for this package before using in production.

OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: fastapi@0.115.6 /requirements.txt SBOM-LICENSE-UNKNOWN
Package fastapi has no license information. This may indicate a compliance risk.

Package: fastapi
Version: 0.115.6
Type: python

Fix: Verify the license for this package before using in production.
OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: cryptography@48.0.1 /requirements.txt SBOM-LICENSE-UNKNOWN
Package cryptography has no license information. This may indicate a compliance risk.

Package: cryptography
Version: 48.0.1
Type: python

Fix: Verify the license for this package before using in production.
OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: actions/setup-python@a26af69be951a21... /.github/workflows/ci.yml SBOM-LICENSE-UNKNOWN
Package actions/setup-python has no license information. This may indicate a compliance risk.

Package: actions/setup-python
Version: a26af69be951a213d495a4c3e4e4022e16d87065
Type: github-action

Fix: Verify the license for this package before using in production.
OWASP: A08:2021-Software and Data Integrity Failures

LOW Unknown License: actions/checkout@11d5960a326750d5838... /.github/workflows/ci.yml SBOM-LICENSE-UNKNOWN
Package actions/checkout has no license information. This may indicate a compliance risk.

Package: actions/checkout
Version: 11d5960a326750d5838078e36cf38b85af677262
Type: github-action

Fix: Verify the license for this package before using in production.
OWASP: A08:2021-Software and Data Integrity Failures

trivy

SCA | 4 findings | Container image and filesystem vulnerability scanner

Severity	Title	File	CWE / Rule
LOW	License Compliance: Apache-2.0 in	LICENSE	LICENSE-Apache-2.0
	Package uses license Apache-2.0 (category: notice). Review for compliance with your organization's license policy.		

Package:
License: Apache-2.0
Category: notice

Fix: Review this finding and apply the appropriate fix based on the description: Package uses license Apache-2.0 (category: notice). Review for compliance with your organization's license policy.
OWASP: A06:2021-Vulnerable and Outdated Components

LOW License Compliance: BSD-3-Clause in jinja2 requirements.txt LICENSE-BSD-3-Clause

```
Package: jinja2
License: BSD-3-Clause
Category: notice
```

OWASP: A06:2021-Vulnerable and Outdated Components

```
Package: httpx
License: BSD-3-Clause
Category: notice
```

OWASP: A06:2021-Vulnerable and Outdated Components

```
Package: PyJWT
License: MIT
Category: notice
```

OWASP: A06:2021-Vulnerable and Outdated Components

This scan analyzed 22 files using 11 security tools across 8 testing categories. Each scanner targets files relevant to its analysis domain (e.g., SAST scanners analyze source code, SCA scanners analyze dependency manifests).

Python: 13 files	Markdown: 2 files
Config: 1 files	Docker: 1 files

.py: 13	.other: 2	.example: 1
.yaml: 1	.dockerfile: 1	.gitignore: 1
.md: 1	.txt: 1	.html: 1

Scanner	Category	Files Analyzed	Scope
trivy	SCA	4	Scanned 4 target(s): pip, dockerfile
gitleaks	Secrets	22	Working directory scanned for 150+ secret p...
opengrep	SAST	13	Multi-language SAST with auto, security-aud...
checkov	IaC	2	IaC security analysis — 0 files, 0 checks (...)
grype	SCA	22	SCA analysis: 0 unique CVEs across 0 vulner...

syft	SBOM	12	SBOM of 12 packages across 1 language(s): p...
package-validator	AI Code Quality	1	Validated 10 packages across 1 dependency f...
oxlint	Code Quality	13	JavaScript (.js, .jsx) and TypeScript (.ts,...
ruff	Code Quality	13	Python linting and security analysis via Ruff
actionlint	CI/CD Security	1	.github/workflows/*.yaml files
jscpd	Code Quality	13	All source files across supported languages
typos	Code Quality	22	All text files in the project

Files with Findings (7):

File Path	Findings	Scanners
/requirements.txt	10	syft
app/main.py	5	ruff
requirements.txt	3	trivy
./github/workflows/ci.yml	2	syft
app/components/memory_integrity.py	2	ruff
app/compliance.py	1	ruff
LICENSE	1	trivy

Software Bill of Materials (12 packages)

Package types: python: 10 | github-action: 2

Top licenses: Unknown (12)

Package	Version	Type	Language	License
actions/checkout	11d5960a326750	github-actio	-	Unknown
actions/setup-python	a26af69be951a2	github-actio	-	Unknown
cryptography	48.0.1	python	python	Unknown
fastapi	0.115.6	python	python	Unknown
httpx	0.28.1	python	python	Unknown
jinja2	3.1.6	python	python	Unknown
numpy	2.2.1	python	python	Unknown
pydantic	2.10.4	python	python	Unknown
pyjwt	2.13.0	python	python	Unknown
pyyaml	6.0.2	python	python	Unknown
qdrant-client	1.12.1	python	python	Unknown
uvicorn	0.34.0	python	python	Unknown